

complainabouttheweather.com

CATW

Security & Architecture Audit

AUDIT DATE

29 May 2026

PREPARED BY

Saad

STATUS

Interim Report

VERSION

1.0

FINDINGS SUMMARY

3 CRITICAL

4 HIGH

6 MEDIUM

5 LOW

Contents

1	Executive Summary
2	Critical Findings — C-1 · C-2 · C-3
3	High Findings — H-1 · H-2 · H-3 · H-4
4	Medium Findings — M-1 through M-6
5	Low Findings — L-1 through L-5
6	What's Working Well
7	Recommended Fix Plan

1. Executive Summary

CATW is functional with several security controls correctly in place. However, three Critical findings and multiple High issues explain the instability experienced during development and pose real risk if unaddressed. The table below summarises every finding.

Ref	Title	Severity	Effort
C-1	Backend on unowned domain	● CRITICAL	Medium
C-2	Verbose error responses leak internals	● CRITICAL	Low
C-3	Frontend HTTPS not enforced	● CRITICAL	Low
H-1	Spaces media URLs never expire	▲ HIGH	Medium
H-2	Public API leaks moderation data	▲ HIGH	Low
H-3	Google Maps Autocomplete deprecated	▲ HIGH	Medium
H-4	Anonymous posting / impersonation	▲ HIGH	Varies
M-1	Admin login is a UI state toggle	◆ MEDIUM	Low–Med
M-2	48 debug logs in production build	◆ MEDIUM	Trivial
M-3	Component re-renders 8× per load	◆ MEDIUM	Medium
M-4	CORS open to all origins	◆ MEDIUM	Low
M-5	Inconsistent API error formats	◆ MEDIUM	Low
M-6	Heavy external dependency payload	◆ MEDIUM	Medium
L-1	Favicon returns HTTP 500	▼ LOW	Trivial
L-2	No SEO / social-share metadata	▼ LOW	Trivial
L-3	SPA — search engines see nothing	▼ LOW	Low–Med
L-4	X-Powered-By: Express header	▼ LOW	Trivial
L-5	Footer copyright year stale	▼ LOW	Trivial

✓ What's Working Well

reCAPTCHA server-side validation · Helmet security middleware · HTTPS + HSTS on the API · Auth/authorisation on protected routes · Socket.io real-time channel · MongoDB cursor-based pagination

3. Critical Findings

Immediate action required

C-1	● CRITICAL
Backend Hosted on a Domain You Do Not Own	
ISSUE The backend runs at catw-backend.sportsstockexchange.co — a domain belonging to the previous developer, not you. IMPACT If that domain expires or is turned off, CATW goes offline immediately with no recovery path. This is the root cause of the instability experienced in development. FIX Migrate to DigitalOcean App Platform under your own account. Point api.complainabouttheweather.com at it. Covered in Phase 2.	
EFFORT	Medium — 12–18 hrs (firm quote after backend code review)

C-2	● CRITICAL
Error Responses Leak Server Internals	
ISSUE Every backend error response includes a full Node.js stack trace, absolute file paths (/var/www/WeatherMood-Backend/), and exact library versions (router@2.2.0). This is OWASP A05:2021 — Security Misconfiguration. IMPACT Attackers gain library versions (enabling CVE lookup), file paths, project structure, and the internal codebase name — all from a single bad request. FIX Set NODE_ENV=production. Update the Express error handler to log stack traces server-side only; return only {status, message} to clients.	
EFFORT	Low — 1–2 hrs

C-3	● CRITICAL
Frontend Does Not Enforce HTTPS	
ISSUE http://www.complainabouttheweather.com does not redirect to HTTPS. No HSTS header is present. IMPACT On hostile networks, credentials and session cookies can be intercepted in plain text. Browsers show 'Not Secure'. Google penalises HTTP pages in search rankings. FIX Add a 301 redirect in .htaccess and set an HSTS header: max-age=31536000; includeSubDomains.	
EFFORT	Low — under 1 hr

4. High Findings

Address in the near term

H-1	▲ HIGH
DigitalOcean Spaces Media URLs Never Expire	
ISSUE Uploaded photos and videos have permanent, unauthenticated public URLs. Deleting a rant does not revoke access to its media.	
IMPACT Deleted or moderated content stays accessible indefinitely. Predictable URL patterns allow bulk scraping of all media ever uploaded.	
FIX Switch to signed URLs with short expiry (15–30 min) generated server-side on demand. Deletion then automatically invalidates access.	
EFFORT	Medium — 4–6 hrs

H-2	▲ HIGH
Public API Returns Internal Moderation Data	
ISSUE The /rants endpoint includes a reports array in every response — the internal record of abuse flags. Currently empty but live.	
IMPACT Once reports accumulate, any caller can see what's been flagged and potentially identify reporters, deterring users from reporting abusive content.	
FIX Add a response serialiser that whitelists only public fields. Strip all moderation metadata before sending.	
EFFORT	Low — 1–2 hrs

H-3	▲ HIGH
Google Maps Places Autocomplete API Is Deprecated	
ISSUE The frontend uses google.maps.places.Autocomplete. Google deprecated this for new customers on 1 March 2025. A deprecation warning fires in the console on every page load.	
IMPACT When the API is retired, location autocomplete in the rant form will break silently. Google has committed to at least 12 months' notice but retirement will come.	
FIX Migrate to google.maps.places.PlaceAutocompleteElement using Google's official migration guide.	
EFFORT	Medium — 3–5 hrs

H-4	▲ HIGH
Anonymous Posting Enables Impersonation	
ISSUE Users post with a freely-typed username and no identity verification. This is an architecture decision, not a bug.	
IMPACT Anyone can post under any real person's name. No user can be banned (only IP, easily bypassed). Moderation is purely reactive; screenshots of harmful posts can spread before removal.	
FIX At minimum: per-IP rate limiting. If impersonation is a serious concern, optional account creation for trusted posters should be discussed.	
EFFORT	Low for rate limiting — Higher if accounts introduced

5. Medium Findings

Reduce stability, performance, or maintainability

M-1	◆ MEDIUM
Admin Login Is a UI State Toggle, Not a Route	
ISSUE The footer admin link toggles a React useState variable — no URL change occurs. The admin panel has no dedicated route.	
IMPACT The login screen can't be bookmarked. Refreshing while the form is open returns to the homepage. Browser back button is broken in this flow.	
FIX Move admin login and panel to dedicated React Router paths (/admin/login, /admin). UI state should derive from the URL, not local component state.	
EFFORT	Low–Med — 3–5 hrs

M-2	◆ MEDIUM
48 Debug Logs in Production Build	
ISSUE The production JS bundle contains console.log('Rants from redux:', ...) and similar. Each fires multiple times per load, dumping a 250-item array to the console.	
IMPACT The browser serialises every logged object on every render — measurable performance cost. Application internals are exposed to anyone who opens DevTools.	
FIX Add esbuild.drop: ['console', 'debugger'] to the Vite production config.	
EFFORT	Trivial — 5 min

M-3	◆ MEDIUM
Main Component Re-renders 8+ Times Per Load	
ISSUE The main Redux-connected component fires 8+ times on each page load with identical data.	
IMPACT Unnecessary re-renders are the leading cause of sluggish React UX, scaling with the rant list size.	
FIX Use memoised selectors (createSelector), useSelector with shallow equality, and React.memo on heavy children. Profile with React DevTools Profiler.	
EFFORT	Medium — 3–5 hrs

M-4	◆ MEDIUM
CORS Open to All Origins	
ISSUE Every API response includes Access-Control-Allow-Origin: * — any website can make requests to the CATW API.	
IMPACT Acceptable for public read endpoints, but it is not a deliberate documented decision. Combined with a missing SameSite cookie attribute it could enable cross-site request attacks.	
FIX Restrict CORS to an explicit allowlist: https://www.complainabouttheweather.com plus any staging domain.	
EFFORT	Low — under 1 hr

M-5	◆ MEDIUM
Inconsistent API Error Response Shapes	
ISSUE Login returns {message}, 404 returns {code, message, stack}, generic errors return {status, message, stack}.	
IMPACT Frontend must special-case each shape. New endpoints risk missing the convention.	
FIX Implement a single unified Express error handler middleware returning {success, status, message} across all endpoints.	
EFFORT	Low — 2–3 hrs

M-6	◆ MEDIUM
Heavy External Dependency Payload	
ISSUE The frontend loads four map/geo providers and four emoji packs from CDNs simultaneously. Total external runtime services: 7+.	
IMPACT Each external service is a live failure point. Four emoji packs add significant download weight for a feature that needs only one.	
FIX Consolidate to one map library, one geocoding provider, and one emoji set.	
EFFORT	Medium — 4–8 hrs

6. Low Findings

Minor issues — quick wins

Favicon Returns HTTP 500

▼ LOW

L-1 Favicon link tag has an empty href. Server returns HTTP 500 on /favicon.ico.

Fix: Add a favicon file and update the link tag to reference it.

Trivial

No SEO or Social-Share Metadata

▼ LOW

L-2 Missing meta description, Open Graph, and Twitter Card tags. Links shared on WhatsApp or social media show no preview.

Fix: Add og:title, og:description, og:image, and meta description to index.html.

Trivial

SPA — Search Engines See Only 'CATW'

▼ LOW

L-3 No SSR or pre-rendering. Crawlers that don't execute JS see only the placeholder text.

Fix: Use Vite's prerender plugin for the public landing page, or accept the SEO limitation.

Low to accept —
Med if SSR
pursued

X-Powered-By: Express Header Exposed

▼ LOW

L-4 Backend advertises its framework on every response.

Fix: Add app.disable('x-powered-by') to Express setup.

Trivial

Footer Copyright Year Hard-Coded as 2025

▼ LOW

L-5 Will become stale every January.

Fix: Use {new Date().getFullYear()} in JSX.

Trivial

7. What's Working Well

Correctly implemented — retain as-is

- ✓

Server-side reCAPTCHA

Validated on the server, preventing bots that bypass the client-side check.
- ✓

Helmet Security Middleware

CSP, HSTS, X-Frame-Options, X-Content-Type-Options all set correctly on the backend.
- ✓

HTTPS on the Backend API

API enforces HTTPS with a 1-year HSTS policy including includeSubDomains.
- ✓

Auth & Authorisation

/auth/me and /admin/* correctly return 401 when accessed without a valid session.
- ✓

Socket.io Real-Time Channel

Connects and delivers daily prompt events successfully.
- ✓

MongoDB Pagination

Cursor-based pagination on /rants is correct for high-write-volume feeds.
- ✓

Maps API Key

Client-side exposure is expected. Confirm it is domain-restricted in Google Cloud Console.

9. Recommended Fix Plan

Each phase can be approved independently at a fixed price

Phase 1

Audit Completion + Frontend Quick Wins

~8–10 hrs

- Complete remaining audit items (admin panel, cookies, Lighthouse, cross-browser)
- Force HTTPS + HSTS on frontend via .htaccess (C-3)
- Strip console.log from production build — one Vite config line (M-2)
- Fix favicon (L-1), add SEO / OG meta tags (L-2), update footer year (L-5)
- Disable X-Powered-By header (L-4)
- Confirm Maps API key is domain-restricted in Google Cloud Console

Phase 2

Backend Migration to DigitalOcean

~12–18 hrs (firm after code review)

- Set up DigitalOcean App Platform under client account
- Migrate env vars, database, and storage references
- Configure SSL and point api.complainabouttheweather.com at new deployment
- Update frontend to call new backend URL; smoke-test all flows
- Phase 5 documentation delivered with this phase
- Estimated running cost: ~\$25–35/month

Phase 3

Backend Hardening

~4–6 hrs

- Remove stack traces from production error responses (C-2)
- Implement signed URLs with short expiry for Spaces media (H-1)
- Strip moderation fields from public /rants response (H-2)
- Restrict CORS to explicit allowlist (M-4)
- Standardise error response shape across all endpoints (M-5)

Phase 4	~3–5 hrs after discussion
Architecture & Product Decisions	
→	Per-IP rate limiting on rant submission (H-4 minimum)
→	Migrate to PlaceAutocompleteElement (H-3)
→	Fix React re-render hotspots (M-3)
→	Move admin login to /admin/login route (M-1)
→	Consolidate map and emoji libraries (M-6)

Phase 5	~2–3 hrs (included in Phase 2)
Handoff Documentation	
→	Where each service is configured (Maps, reCAPTCHA, Spaces, App Platform)
→	How to rotate API keys and credentials
→	Backend deployment procedure
→	Troubleshooting guide — what to check first when something breaks
→	Monthly cost breakdown and scaling thresholds

Audit performed by Saad — 29 May 2026.